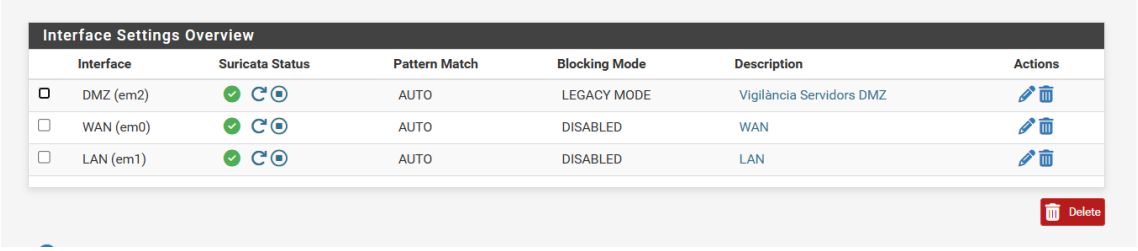
Definició de Polítiques de Seguretat

Definició de regles i signatures per zones de la xarxa especifiques

Accedim a la configuració de Suricata i obrim la interfície que volem editar:



Interface Settings Overview

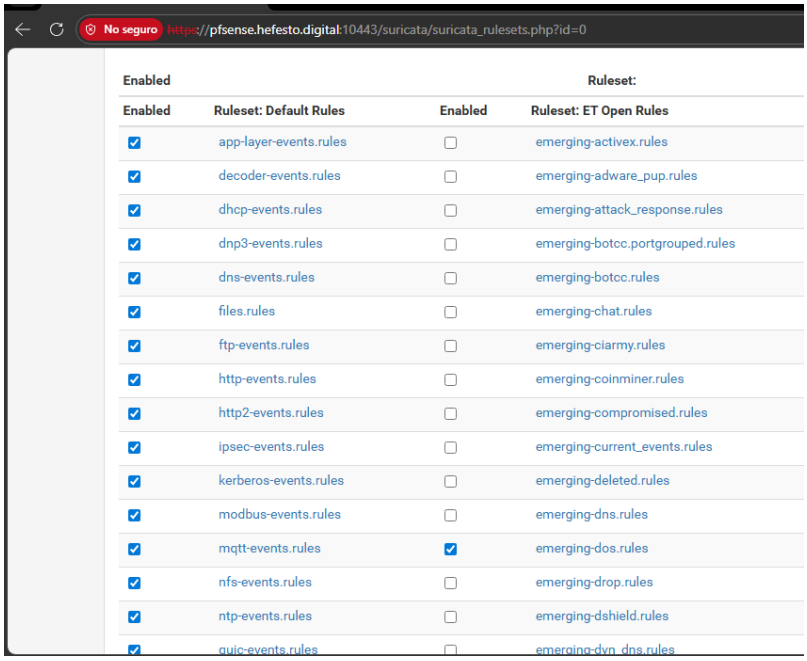
Interface	Suricata Status	Pattern Match	Blocking Mode	Description	Actions
DMZ (em2)		AUTO	LEGACY MODE	Vigilància Servidors DMZ	
WAN (em0)		AUTO	DISABLED	WAN	
LAN (em1)		AUTO	DISABLED	LAN	

Delete

DMZ

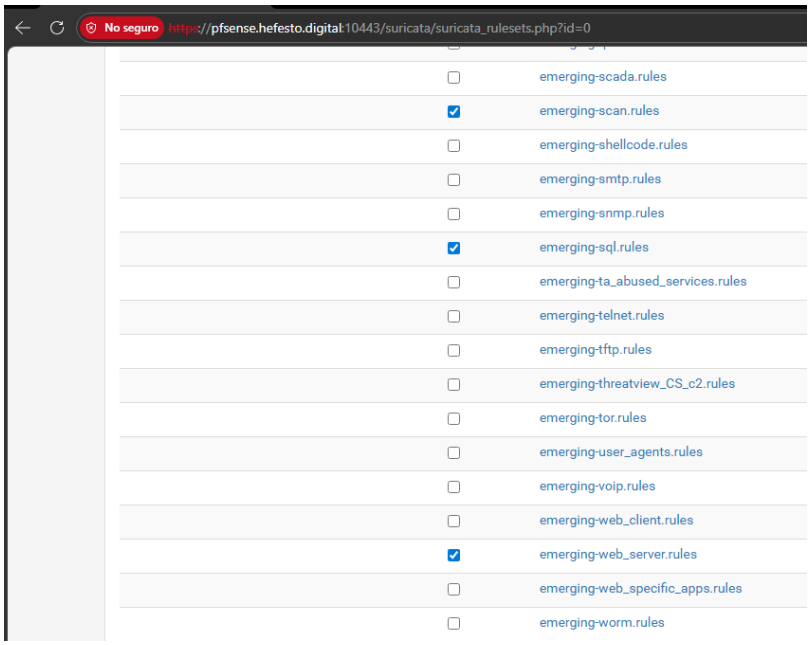
Per protegir la DMZ, s'han activat diferents categories de regles d'Emerging Threats (ET) que són les que em comentat anteriorment, son molt útils ja que inclouen molts patrons diferents a detectar, per la DMZ s'han activat les següents:

- **emerging-web_server.rules:** Per tenir protecció contra exploits que van dirigits a serveis HTTP.
- **emerging-sql.rules:** Filtre de paquets que continguin patrons d'atac a bases de dades.
- **emerging-scan.rules:** Detecció d'escanejos de ports (Nmap) provinents de la WAN.
- **emerging-dos.rules:** Identificació d'intents de denegació de servei (quan els atacants saturen la red enviant molts paquets).

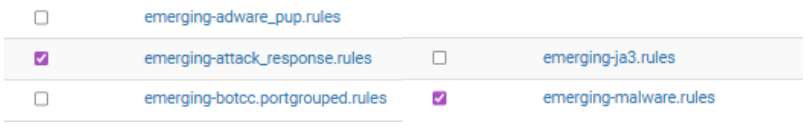


No seguro https://pfsense.hefesto.digital:10443/suricata/suricata_rulesets.php?id=0

Enabled	Ruleset: Default Rules	Enabled	Ruleset: ET Open Rules
	app-layer-events.rules		emerging-activex.rules
	decoder-events.rules		emerging-adware_pup.rules
	dhcp-events.rules		emerging-attack_response.rules
	dnp3-events.rules		emerging-botcc.portgrouped.rules
	dns-events.rules		emerging-botcc.rules
	files.rules		emerging-chat.rules
	ftp-events.rules		emerging-ciarmy.rules
	http-events.rules		emerging-coinminer.rules
	http2-events.rules		emerging-compromised.rules
	ipsec-events.rules		emerging-current_events.rules
	kerberos-events.rules		emerging-deleted.rules
	modbus-events.rules		emerging-dns.rules
	mqtt-events.rules		emerging-dos.rules
	nfs-events.rules		emerging-drop.rules
	ntp-events.rules		emerging-dshield.rules
	quic-events.rules		emerging-dyn_dns.rules



Després de revisar els conjunts de regles disponibles, s'ha decidit afegir també **emerging-attack_response.rules** i **emerging-malware.rules**, ja que aporten detecció davant activitats malicioses relacionades amb malware.



LAN

Com que la LAN es només per monitorització interna (IDS) i no per bloquejar serveis exposats només activarem les següents regles:

- **emerging-scan.rules**: Per detectar escanejos interns o moviment lateral entre les maquines.
- **emerging-malware.rules**: Para detectar tràfic sospitós d'equips compromesos degut a algun malware.
- **emerging-attack_response.rules**: Para ver comportaments causats per una intrusió o activitats sospitoses.

Ruleset:

Enabled	Ruleset: ET Open Rules
☐	emerging-activex.rules
☐	emerging-adware_pup.rules
☑	emerging-attack_response.rules
☐	emerging-botcc.portgrouped.rules
☐	emerging-botcc.rules
☐	emerging-chat.rules
☐	emerging-ciarmy.rules
☐	emerging-coinminer.rules
☐	emerging-compromised.rules
☐	emerging-current_events.rules
☐	emerging-deleted.rules
☐	emerging-dns.rules
☐	emerging-dos.rules
☐	emerging-drop.rules
☐	emerging-dshield.rules
☐	emerging-dyn_dns.rules
☐	emerging-exploit.rules
☐	emerging-exploit_kit.rules
☐	emerging-file_sharing.rules
☐	emerging-ftp.rules
☐	emerging-games.rules
☐	emerging-hunting.rules
☐	emerging-icmp.rules
☐	emerging-imap.rules
☐	emerging-inappropriate.rules
☐	emerging-info.rules
☐	emerging-ja3.rules
☑	emerging-malware.rules
☐	emerging-misc.rules
☐	emerging-mobile_malware.rules
☐	emerging-netbios.rules
☐	emerging-p2p.rules
☐	emerging-phishing.rules
☐	emerging-pop3.rules
☐	emerging-remote_access.rules
☐	emerging-retired.rules
☐	emerging-rpc.rules
☐	emerging-scada.rules
☑	emerging-scan.rules
☐	emerging-shellcode.rules
☐	emerging-smtp.rules

WAN

Activem únicament les següents regles per tal de no generar molt de soroll ja que només volem tallar intents d'accés externs que no siguin connexions normals a la WEB DMZ o accessos per VPN:

- **emerging-scan.rules**: Per detectar escanejos des de Internet, que es molt típic.
- **emerging-dos.rules**: Per identificar intents de saturació de la nostra xarxa.
- **emerging-malware.rules**: Per detectar comunicacions sospitoses o associades a malware.

☑	emerging-dos.rules
☐	emerging-drop.rules
☐	emerging-dshield.rules
☐	emerging-dyn_dns.rules
☐	emerging-exploit.rules
☐	emerging-exploit_kit.rules
☐	emerging-file_sharing.rules
☐	emerging-ftp.rules
☐	emerging-games.rules
☐	emerging-hunting.rules
☐	emerging-icmp.rules
☐	emerging-imap.rules
☐	emerging-inappropriate.rules
☐	emerging-info.rules
☐	emerging-ja3.rules
☑	emerging-malware.rules
☐	emerging-misc.rules
☐	emerging-mobile_malware.rules
☐	emerging-netbios.rules
☐	emerging-p2p.rules
☐	emerging-phishing.rules
☐	emerging-pop3.rules
☐	emerging-remote_access.rules
☐	emerging-retired.rules
☐	emerging-rpc.rules
☐	emerging-scada.rules
☑	emerging-scan.rules

Establiment de mecanismes de resposta a incidents

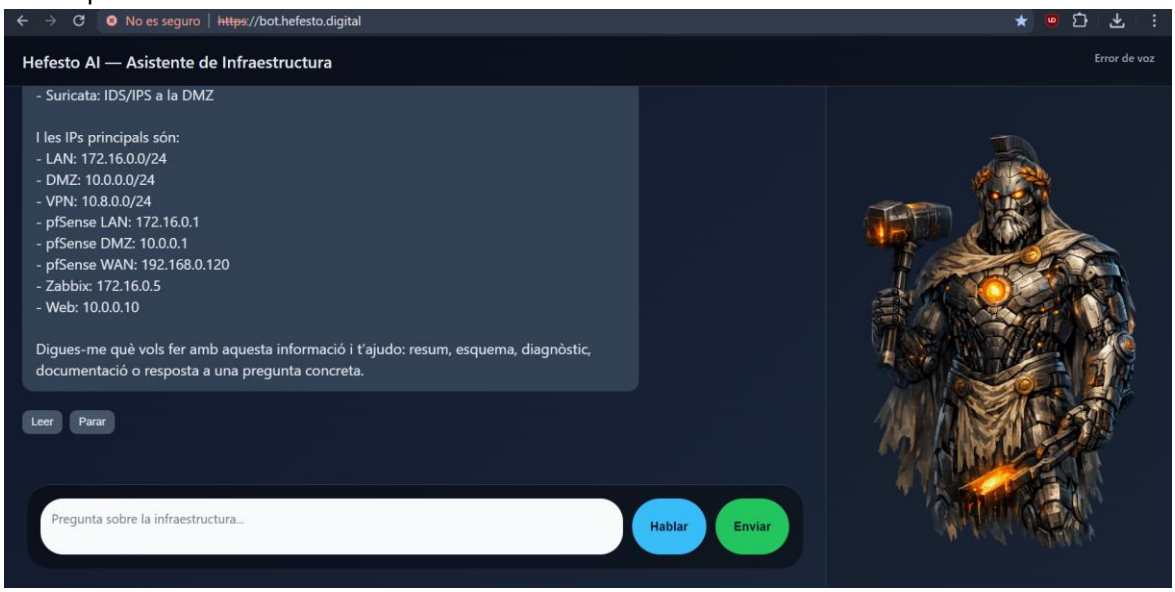
A més de la detecció d'amenaces, em definit mecanismes de resposta adaptats a cada zona de la xarxa per tal que el sistema a part d'identificar activitats sospitoses també pugui actuar davant possibles incidents de seguretat.

A la **DMZ** que es on tenim serveis exposats a fora com la nostra web em fet que Suricata funcioni en mode IPS, per fer-ho s'ha activat el bloqueig automàtic de hosts amb la opció **Block Offenders**, això permet tallar connexions o bloquejar trànsit maliciós quan una regla genera una alerta, d'aquesta manera protegim de manera immediata els servidors exposats.

Tant a les interfícies configurades en mode IPS **(DMZ** i **WAN)**, com a la interfície configurada en mode IDS **(LAN)**, Suricata s'encarrega de detectar i registrar les alertes. Les alertes es guarden tant al **System Log** com en format **EVE JSON**, permetent la seva revisió posterior i la integració amb sistemes de monitorització com **Zabbix**.

Al tenir tota la seguretat centralitzada a pfSense podem tenir un millor control de la infraestructura, també implementarem un servei de IA per tal de poder obtenir resums de les dades i alertes que nosaltres li facilitem cridant a la API de openai des de una web que em ubicat a la LAN i que mostrarem més endavant un cop finalitzat el projecte.

Prototip de servidor de IA a la LAN:



En el següent punt d'anàlisi i logs mostraré la integració amb Zabbix que serà des de on analitzarem els Logs que vagin entrant.